

MedDefense Health Systems

Security Strategy Document

Prepared by: **Security Analyst** | Prepared for: **The Board of Directors, MedDefense Health Systems** | Date: **[assessment date]**

Companion documents: **Security Posture Assessment (1x00)**, **Threat Landscape Report (1x01)**, **Vulnerability Assessment Summary (1x02)**

■ **Navy bold** = report skeleton (fixed structure / section labels — reusable in any report) ■ **Maroon** = filled-in data (specific to this assessment)

1. Executive Summary

MedDefense's current risk posture is best summarized in one line: **prevention exists in fragments, detection barely exists at all, and the organization has already been compromised twice through the exact same open door.** Three weeks of assessment (1x00–1x02) found an organization with no formal security framework, no MFA anywhere, zero detection capability, and a flat network that turns every single vulnerability into an organization-wide risk. This document adopts **NIST CSF 2.0 as the strategic backbone and CIS Controls v8 (IG1, then IG2) as the operational implementation layer** (Task 0), applies quantitative risk analysis (SLE/ARO/ALE) rather than color-coded severity labels to every major decision, and translates the result into a fully-costed, Board-approvable plan.

Total investment requested: \$103,400 of the Board-approved \$120,000 security budget (Task 8), delivering an estimated \$587,750 in combined annual risk reduction — approximately \$5.68 returned in avoided expected loss for every dollar spent.

Top 3 priority actions: (1) Enable MFA on VPN and administrative accounts using existing O365 licensing — \$4,000, \$204,000 net benefit; (2) Deploy a SIEM (Wazuh) to close MedDefense's single most systemic gap, the complete absence of detection capability — \$28,000, \$122,000 net benefit; (3) Disable the confirmed-active Ghostcat vulnerability on the EHR application server — \$500, \$469,750 net benefit, the highest-return action in this entire program.

2. Governance Framework

Framework selection (Task 0): MedDefense adopted NIST CSF 2.0 for strategic direction and CIS Controls v8 for implementation, deferring formal ISO 27001 certification until the underlying program matures — certifying a management system before the controls it would certify exist would be certifying nothing.

NIST CSF Current vs. Target Profile (Task 1): Govern and Detect/Respond are rated Not Implemented today — no documented risk strategy, no CISO, and detection limited to "we check manually if something breaks." Identify and Protect are Partial — a real Asset Registry and vulnerability data now exist, but no internal process sustains them, and real controls exist but exclude MFA and server-level antivirus entirely. Recover is Partial, with a working but untested backup. **Target in 6 months:** Govern and Recover reach Managed; Identify reaches Managed; Protect reaches Managed; Detect reaches Partial (Phase 1 SIEM live); Respond reaches Partial (a first documented IR plan, table-top tested).

CIS Controls maturity scorecard (Task 2): Of 18 controls, zero are fully Implemented, 8 are Partial, and 10 are Not Implemented — the same "prevention in fragments, nothing complete end-to-end" pattern identified across every prior project. Top 5 priority controls identified: Access Control Management (MFA), Network Infrastructure Management (segmentation), Audit Log Management (detection), Continuous Vulnerability Management, and Data Recovery.

Governance structure (Task 4): A RACI matrix assigns the CEO as Accountable for budget approval, policy approval and risk acceptance; the Deputy CISO as Accountable for day-to-day program execution; and, critically, Department Heads now carry direct Responsibility for their own staff's security training completion — directly addressing the 58–71% training completion rate found in 1x00. MedDefense currently has no CISO, only a Deputy; this strategy recommends engaging a virtual CISO (vCISO) at approximately \$48,000/year — funded separately from the \$120,000 technical budget — rather than a full-time hire that would consume the entire technical program's funding on a single salary.

3. Quantitative Risk Analysis

Top 5 risks by ALE (Task 6):

Risk	ALE
Ghostcat exposes EHR database credentials	\$495,000
Ransomware encrypts domain-joined systems	\$300,000
Billing server repeat RCE-to-root	\$189,200
Insider data exfiltration (malicious departure)	\$70,000
Medical device compromise (DoS + patient safety)	\$43,000

Risk Register (Task 10): 10 risks tracked, spanning Compliance, Strategic, Financial, and Operational categories, each with a named owner, treatment decision, planned control, residual risk estimate, and Key Risk Indicator. All 10 currently carry a Mitigate decision, refined in Section 7 below.

Risk Appetite (Task 16): MedDefense accepts risk only when mitigation cost is genuinely disproportionate to the exposure removed, or when a real operational/contractual constraint blocks immediate action — never as a substitute for affordable mitigation. Patient safety risks are an absolute limit requiring compensating controls even when temporarily accepted, and any acceptance above \$150,000 in ALE or touching patient safety requires CEO sign-off.

4. Control Strategy

Cost-benefit results (Task 7): Of 8 evaluated controls, MFA delivered the single highest net value (\$200,000) at the lowest cost (\$4,000); the "premium" medical-device isolation-with-monitoring option was the one control that failed its own cost-benefit test (-\$16,300 net value) and was rejected outright.

Budget allocation (Task 8): \$103,400 funded this cycle — MFA, SIEM Phase 1, offsite backup replication, full network segmentation, a Westside firewall replacement, and a scoped server-only EDR upgrade — leaving \$16,600 in reserve. The 24/7 outsourced SOC and full-fleet EDR expansion are deferred, not because they lack value, but because funding them first would have starved five higher-combined-value controls.

Control selection with framework mapping (Task 11): Every funded control maps explicitly to a CIS Control safeguard and a NIST CSF function, with MFA identified as the architectural foundation multiple other controls

(vendor-account MFA, SIEM triage load) depend on.

Quick wins (Task 13): Five zero-cost actions requiring no budget approval — disabling the Ghostcat AJP connector, restricting the EHR database to its application server, resetting default medical-device credentials, deploying MFA, and enabling USB restriction on clinical workstations — collectively deliverable within 10 days using resources MedDefense already has.

5. Architecture Recommendations

Network segmentation design (Task 14): Five zones — Server, Clinical Workstation, Medical Device, Management, and Guest/IoT — replace the current flat `10.10.0.0/16` network, governed by a default-deny policy between zones with narrow, explicit exceptions.

Kill chain disruption analysis: This design disrupts 4 of MedDefense's 5 documented kill chains (80%), breaking the flagship ransomware kill chain decisively at its network-discovery step. The one chain it cannot touch — insider exfiltration via already-legitimate access — is a structurally different problem requiring access-governance controls (deprovisioning, export monitoring), not network architecture, and is addressed separately in Section 7.

6. Policy Foundation

AUP summary (Task 12): A 2–3 page Acceptable Use Policy grounds every prohibition in a real MedDefense incident rather than generic language — the shared-device incidents from 1x00, the USB findings from 1x02 — and requires MFA and individual accountability organization-wide, including for physicians and executives, with no exceptions.

Policy roadmap: Beyond the AUP, MedDefense needs, in priority order: (1) an Incident Response Plan within the next 60 days, tied directly to the Respond function's current Not Implemented rating; (2) a Data Retention and Disposal Policy within 90 days, formalizing the data classification work from 1x00 Task 9; (3) a Vendor Security Requirements Policy within 120 days, addressing the currently ungoverned MedTech Solutions relationship (Risk Register RISK-010); (4) a Change Management Policy within 6 months, closing GAP-016 identified in 1x01.

7. Residual Risk Assessment

Red team findings (Task 15): Assuming every funded control is fully operational, the insider exfiltration kill chain remains completely unaddressed — its dedicated control (automated deprovisioning + export monitoring, \$8,000) was quantified in Task 6 but never actually competed for funding in the Task 7/8 process, despite \$16,600 sitting unspent. A second finding: the segmentation fix for the EHR database (restricting access to `ehr-srv-01` alone) does not close the vendor-mediated path, since a compromised legitimate vendor session on `ehr-srv-01` inherits exactly the access that host is designed to have. **Overall residual risk: Medium** — the highest-probability, historically-proven paths are substantially closed, but two real, distinct paths remain open.

Accepted risks (Task 16): Three risks are formally accepted rather than further mitigated: the Windows XP MRI workstation (pending scheduled replacement in 18 months, compensated by segmentation and physical access controls), the residual medical-device risk beyond basic segmentation (the "premium" version costs more than the risk it removes), and the after-hours detection gap from deferring 24/7 SOC coverage this cycle (compensated by Phase 1 SIEM plus monthly Risk Register review).

Year 2 priorities: Fund the previously-unfunded insider-risk control (\$8,000) immediately rather than waiting — it should not require a Year 2 budget cycle at all, given remaining Year 1 reserve. For Year 2 proper: mature the SIEM

beyond Phase 1 to include application- and database-layer behavioral monitoring for vendor sessions specifically, the only remaining path to closing the vendor-mediated Kill Chain #5 bypass.

8. Implementation Roadmap

Full month-by-month detail in Task 18 (6-Month Security Roadmap); summarized here.

- **Phase 1 (Months 1–2):** Quick wins (Task 13) executed within the first 2 weeks; procurement initiated for SIEM labor, backup replication, and segmentation hardware/design.
- **Phase 2 (Months 3–4):** Core controls deployed — MFA organization-wide, SIEM Phase 1 live and tuned, network segmentation implemented zone by zone, backup replication operational.
- **Phase 3 (Months 5–6):** Validation — segmentation reachability testing, SIEM alert-response drills, a first table-top Incident Response Plan exercise, and a full re-scan confirming the Immediate/Short-term vulnerability findings from 1x02 remain resolved.

Success metrics per phase: Phase 1 — all 5 quick wins verified complete; Phase 2 — MFA enforced on 100% of in-scope accounts, SIEM generating and being triaged for daily alerts, segmentation reachability tests passing; Phase 3 — zero unresolved Critical findings on re-scan, a signed-off IR plan, and a Risk Register review showing no risk without an assigned owner or KRI.

9. Next Steps

Vulnerabilities are identified, prioritized, and mapped to threats. The strategy to address them is designed, costed, and approved. The next step moves from strategy to implementation at the technical layer: Project 1x04 (Cryptographic Foundation) will design the specific encryption, key management, and cryptographic controls needed to make good on the data-protection commitments this document makes in Section 6 — turning "Restricted data must be encrypted" from a policy statement into a specific, implemented technical standard. This document is the bridge between knowing what MedDefense must do and building the specific mechanisms that do it.

Board Pitch — One-Page Executive Version

Current State: Four weeks of assessment found an organization with no security framework, no way to detect an attack in progress, and a network where every system can reach every other system. The verdict: we are not unlucky — we are unprotected, and it has already cost us twice.

The Risk: Our own data shows a ransomware attack that encrypts patient records and locks down billing carries an expected annual cost of \$300,000 — not a worst case, the actuarially expected cost of leaving today's gaps open. That number is built from a threat pattern that has already hit us once, through a door that is still unlocked.

The Plan: We recommend investing \$103,400 of the approved \$120,000 in five specific fixes, not a general "more security" purchase. The top three: multi-factor authentication using software we already own (\$4,000), a monitoring system that finally lets us detect an attack instead of discovering it by accident weeks later (\$28,000), and closing one confirmed, actively-exploited flaw on our patient-records server (\$500). Together with two additional fixes — protected backups and a real perimeter at our Westside clinic — this plan closes over half a million dollars in identified annual risk, verified with the same rigor a financial audit would demand.

The Return: For every dollar spent, we avoid approximately \$5.68 in expected annual loss — a return few other investments this Board reviews this year will match, because unlike most spending decisions, the cost of not acting is not hypothetical. It is a number built from what already happened to us.